

2026 年度 CCF-蚂蚁科研基金

项 目 名 称

面向链上程序安全的智能体驱动型漏洞验证与安全修复方
法研究

申报课题：面向区块链资产安全的智能体驱动型安全分析与风险治理研究

申请者姓名	曹阳
CCF会员码	U4310M
所属机构	东南大学
提交日期	2026年5月6日

目录

1. 项目介绍

1.1. 基金题目

1.2. 背景及研究意义

1.3. 研究目标

1.4. 研究方法

2. 研究计划

2.1. 项目期限（一般是一年期）

2.2. 项目计划（一般分为三或四个阶段）

3. 预期成果（算法原型，论文，专利，人才，技术指标等）

4. 人力、设备等投入及项目预算

4.1. 人力投入

4.2. 设备投入

4.3. 项目总预算

5. 学者个人简历

1. 项目介绍

1.1 题目

面向链上程序安全的智能体驱动型漏洞验证与安全修复方法研究

1.2 背景及研究意义

随着蚂蚁数字科技区块链与 Web3 业务的持续推进，链上资产正在从传统金融标准化产品，逐步延伸到**算力、新能源、供应链等复杂实体资产上链场景**。与普通代币合约不同，实体资产上链不仅涉及资产登记和流转，还涉及资源计量、状态更新、服务履约、收益结算和多方协同等复杂业务逻辑。链上程序一旦存在安全缺陷，风险不再局限于单个合约函数，而可能沿着业务链路传导，造成资产错配、重复结算、收益错分、服务履约状态伪造或关键资产冻结等实际业务后果。

具体而言，在**算力资产上链场景**中，链上程序需要记录算力资源登记、算力计量、资源分配、服务履约和收益结算等流程。若存在状态更新异常、跨合约调用异常或经济激励机制设计缺陷，攻击者可能通过伪造资源状态、重复触发结算、操纵履约结果等方式影响算力收益分配。在**新能源资产上链场景**中，链上程序可能涉及发电量计量、绿色权益登记、收益分配、价格更新和多方结算等逻辑，若计量状态、结算状态和权限控制之间存在不一致，可能导致收益错配、重复登记或结算异常。在**供应链资产上链场景**中，链上程序承载资产确权、仓单流转、质押融资、清算处置等业务流程，若跨合约调用、状态迁移和资产流转之间缺少一致性保障，可能引发重复质押、异常清算、权限绕过或资产冻结等风险。因此，**链上程序安全已经不只是传统代码审计问题**，而是区块链资产安全治理中的关键基础能力。

现有链上程序安全分析方法主要可以分为三类。**第一类是基于规则、模式匹配和静态程序分析的方法**。这类方法能够高效发现重入、未检查外部调用、权限控制缺陷等已知漏洞模式，但主要依赖预定义规则或符号约束，对跨合约调用、复杂业务状态和资产流转语义的理解仍然有限，容易在复杂链上业务中产生误报或漏报。**第二类是基于符号执行、模糊测试和动态执行验证的方法**。这类方法能够通过测试输入生成、交易执行和运行时行为观察来验证部分漏洞，但在多交易组合、状态空间复杂、业务前置条件难以构造的场景中，仍面临路径爆炸、执行成本高和攻击路径覆盖不足等问题。**第三类是近年来出现的基于大语言模型和智能体的安全分析方法**。大模型具备较强的代码理解、漏洞解释和修复建议生成能力，但如果缺少结构化上下文、执行反馈和业务语义约束，容易出现推理幻觉、

攻击路径不可执行、风险判断不可复核、修复建议破坏业务逻辑等问题。此外，在链上资产业务的实际运行过程中，安全风险往往不仅体现在合约源码中，也会通过交易调用流量、DApp 访问行为、事件日志和账户交互关系表现出来。现有方法通常更关注合约源码、局部漏洞模式或单次交易执行，对运行时交易流量、调用序列和资产流转异常的利用不足，导致难以及时发现已上线业务中的异常攻击行为，也难以将静态漏洞线索与真实运行风险进行关联。因此，有必要将链上程序语义分析与运行时流量分析结合起来，形成面向上线前审查和运行中风险发现的一体化安全治理能力，使链上程序安全分析从“局部漏洞检测”进一步走向“可验证、可解释、可辅助修复”的闭环式风险治理。

结合蚂蚁链上资产业务需求和现有方法不足，本项目拟重点解决以下三个关键技术问题。

关键技术问题一：链上资产业务中漏洞触发路径与资产影响路径难以统一刻画

在算力计量、资源分配、服务履约、收益结算等链上资产业务中，漏洞触发往往不是单一代码语句导致，而是代码控制流、合约状态变化和资产价值流转之间的耦合异常。例如，某一跨合约调用在代码层面可能合法，但如果其触发了错误的状态更新顺序、异常的资源分配逻辑或错误的收益结算路径，就可能造成资产错配或经济损失。现有方法多从局部代码模式、单一调用链或局部状态约束出发，难以统一刻画代码控制流、状态依赖流与资产价值流之间的耦合关系，也难以揭示漏洞触发路径与资产影响路径之间的映射关系。进一步地，链上程序上线运行后，真实交易流量和事件日志中往往包含大量可用于风险判断的动态证据，例如异常调用频率、异常调用序列、异常跨合约交互、异常资产聚集和异常收益分配等。如果不能将这些运行时行为证据与代码控制流、状态依赖流和资产价值流进行关联，就难以判断某一静态风险点是否具有真实触发可能，也难以及时发现已上线业务中的持续性、组合式或低频隐蔽攻击行为。因此，如何将程序语义图谱与运行时流量行为进行统一建模，是链上资产安全治理中的基础问题。

关键技术问题二：大模型/智能体漏洞推理缺少结构化证据约束，攻击路径可执行性不足

大语言模型和智能体能够辅助代码理解、漏洞解释和攻击路径推演，但在复杂链上资产业务中，如果缺少合约调用、状态依赖、资产流转和业务规则等结构化证据约束，模型容易产生上下文遗漏、推理跳跃和不可执行攻击路径。对于算力收益结算、供应链质押清算、新能源资产计量等场景，仅给出自然语言风险判断并不能满足安全复核要求。如何在结构化证据约束下组织多智能体分工推演，并利用 PoC 执行、交易重放和沙箱反馈校正模型推理偏差，是实现从自然语言风险判断到可复核漏洞证据链转化的关键问题。

关键技术问题三：漏洞修复建议缺少业务语义一致性验证，可能引入次生资产风险

链上程序修复不能只阻断局部攻击路径，还必须保证正常业务流程中的**权限控制、状态迁移、资产登记、收益结算和清算处置逻辑不被破坏**。若补丁改变了正常状态流转、资产分配规则或收益结算逻辑，可能引入资产冻结、重复结算失败、合法质押无法赎回、收益分配异常等次生风险。因此，如何在生成修复建议的同时，引入**安全约束、状态等价约束和资产语义等价约束**，验证补丁既能阻断已确认攻击路径，又不破坏正常业务语义，是链上程序安全修复落地中的核心问题。

本项目的研究意义在于，将代码漏洞检测、结构化程序分析、运行时流量分析、多智能体推理、PoC 动态验证和安全约束修复建议生成技术，迁移到蚂蚁链上资产业务的具体安全治理场景中。相比传统静态审计方法，本项目强调**代码控制流、状态依赖流、资产价值流与运行时行为证据的耦合建模**，利用**交易流量、事件日志和沙箱执行反馈验证风险真实性**，也更强调**修复建议与链上资产操作语义之间的一致性验证**。项目成果有望形成一套面向链上程序安全审查的**智能化分析原型**，为蚂蚁链上资产场景中的上线前审查、高风险合约复核、运行中风险发现和漏洞整改处置提供可落地的技术支撑。

参考文献：

- [1] N. Hejazi and A. H. Lashkari, “A comprehensive survey of smart contracts vulnerability detection tools: Techniques and methodologies,” *Journal of Network and Computer Applications*, vol. 237, Art. no. 104142, 2025.
- [2] S. Chaliasos, M. A. Charalambous, L. Zhou, R. Galanopoulou, A. Gervais, D. Mitropoulos, and B. Livshits, “Smart contract and DeFi security tools: Do they meet the needs of practitioners?” in *Proc. IEEE/ACM 46th Int. Conf. Software Engineering (ICSE)*, 2024, pp. 60:1–60:13.
- [3] S. Wu, Z. Li, L. Yan, W. Chen, M. Jiang, C. Wang, X. Luo, and H. Zhou, “Are we there yet? Unraveling the state-of-the-art smart contract fuzzers,” in *Proc. IEEE/ACM 46th Int. Conf. Software Engineering (ICSE)*, 2024, pp. 127:1–127:13.
- [4] H. Yang, X. Gu, X. Chen, L. Zheng, and Z. Cui, “CrossFuzz: Cross-contract fuzzing for smart contract vulnerability detection,” *Science of Computer Programming*, vol. 234, Art. no. 103076, 2024.
- [5] S. J. Wang, K. Pei, and J. Yang, “SmartInv: Multimodal learning for smart contract invariant inference,” in *Proc. IEEE Symposium on Security and Privacy (SP)*, 2024, pp. 2217–2235.
- [6] Z. Wang, J. Chen, Y. Wang, Y. Zhang, W. Zhang, and Z. Zheng, “Efficiently detecting reentrancy vulnerabilities in complex smart contracts,” *Proceedings of the ACM on Software Engineering*, vol. 1, no. FSE, pp. 161–181, 2024.
- [7] C. Chen, J. Su, J. Chen, Y. Wang, T. Bi, J. Yu, Y. Wang, X. Lin, T. Chen, and Z. Zheng, “When ChatGPT meets smart contract vulnerability detection: How far are we?” *ACM Transactions on Software Engineering and Methodology*, vol. 34, no. 4, Art. no. 100, pp. 100:1–100:30, 2025.
- [8] C. Wang, J. Zhang, J. Gao, L. Xia, Z. Guan, and Z. Chen, “ContractTinker: LLM-empowered

vulnerability repair for real-world smart contracts,” in Proc. 39th IEEE/ACM Int. Conf. Automated Software Engineering (ASE), 2024, pp. 2350–2353.

[9] Z. Kong, C. Zhang, M. Xie, M. Hu, Y. Xue, Y. Liu, H. Wang, and Y. Liu, “Smart contract fuzzing towards profitable vulnerabilities,” Proceedings of the ACM on Software Engineering, vol. 2, pp. 153–175, 2025.

1.3 研究目标

本项目面向蚂蚁区块链与 Web3 业务中的链上实体资产安全场景，**聚焦算力、新能源、供应链等资产**上链过程中的链上程序安全审查与运行中风险发现需求，拟构建智能体驱动的链上程序漏洞验证与安全修复方法，融合合约源码、ABI、交易日志、事件日志、DApp 调用流量和账户交互行为等多源证据，形成“建模—推演—验证—评估—修复—再验证”的闭环能力。

目标一：构建控制流—状态流—价值流与运行时行为证据耦合的链上程序语义建模方法

针对算力计量、资源分配、服务履约、收益结算、供应链确权与质押清算等链上业务中代码逻辑、状态变化、资产流转和运行时行为高度耦合的问题，本项目拟构建代码控制流、状态依赖流、资产价值流与运行时行为证据的统一建模方法。

具体而言，项目将从合约源码、ABI、部署配置、交易日志、事件日志、DApp 调用流量、账户交互行为、业务接口文档和审计规则中抽取函数调用、跨合约调用、权限检查、状态变量读写、履约状态迁移、资产登记、资源分配、收益结算、清算流转、异常调用频率、异常调用序列和异常资产流向等信息，建立“**控制流—状态流—价值流—运行时行为证据**”耦合表示。通过该目标，系统能够刻画“代码调用如何触发状态变化、状态变化如何影响资产流转、资产流转异常如何反映在交易流量和事件日志中”的链路关系，从而建立漏洞触发路径、资产影响路径与运行时异常行为之间的映射。

该目标预期支撑对状态更新异常、跨合约调用异常、重复结算、权限绕过、资源分配异常、经济激励攻击、异常高频调用、异常交易序列和异常资产聚集等问题的识别，为上线前安全审查、复杂漏洞路径恢复和运行中风险发现提供结构化基础。

目标二：构建结构化证据约束的多智能体漏洞推演与 PoC 动态验证机制

针对大模型和智能体在链上资产业务场景中容易出现推理跳跃、上下文遗漏和攻击路径不可执行的问题，本项目拟构建**结构化证据约束**下的多智能体漏洞推演与 PoC 动态验证机制。

具体而言，项目将基于目标一形成的控制流、状态流和价值流证据，设计代码解析 Agent、

漏洞检测 Agent、攻击路径推演 Agent、PoC 生成 Agent、沙箱执行 Agent 和结果裁决 Agent。各智能体不直接进行自由推理，而是围绕合约调用证据、状态变化证据、资产流转证据和业务规则证据进行分工分析，输出漏洞类型、触发条件、调用序列、状态变化、资产影响路径和验证方式等结构化结果。

该目标预期通过 **PoC 执行、交易重放和沙箱反馈**，校正模型推理偏差，将自然语言风险判断转化为**可复核漏洞证据链**。对于算力收益重复结算、供应链质押状态异常、新能源收益分配异常等高风险场景，系统能够判断漏洞是否真实可触发，并输出执行日志、调用轨迹、状态变化和资产影响说明，支撑高风险合约复核。

目标三：构建面向链上资产操作语义的约束修复与等价性验证方法

针对链上程序修复容易阻断局部漏洞却破坏业务逻辑的问题，本项目拟构建面向链上资产操作语义的安全约束修复与等价性验证方法。

具体而言，项目将围绕算力资源分配、服务履约状态更新、收益结算、新能源资产计量、供应链资产确权、质押与清算等业务操作，定义修复过程中的**安全约束和业务语义约束**。其中，安全约束要求补丁必须阻断已验证攻击路径；状态等价约束要求补丁不能破坏正常服务履约状态迁移；资产语义等价约束要求补丁不能改变正常资源分配、资产登记、收益结算和清算处置逻辑。

该目标预期形成安全修复建议生成、回归测试、交易重放和沙箱再验证机制。系统最终输出修复建议、修复依据、补丁验证结果和残余风险说明，确保补丁在阻断攻击路径的同时，不引入资产冻结、重复结算、权限异常、收益错分等次生风险。

总体预期目标

通过上述研究，本项目预期形成一套面向链上实体资产业务的**智能体驱动型安全分析原型系统**，具备以下能力：

- 1.面向算力、新能源、供应链等链上资产业务，构建控制流—状态流—价值流**耦合图谱**；
- 2.基于结构化证据约束多智能体完成**漏洞推演、PoC 生成、交易重放和沙箱验证**；
- 3.对已验证漏洞进行**风险评估、处置优先级排序和安全约束修复建议生成**；
- 4.通过**回归测试和再验证**确认补丁不破坏链上资产操作语义；
- 5.支撑蚂蚁链上资产业务中的**上线前代码审查、高风险合约复核、运行中风险发现和漏洞整改处置**。

1.4 研究方法

本节围绕上述三个研究目标，给出具体技术路线。项目总体技术路线如图 1 所示，系统以合约源码、ABI、部署配置、交易日志、事件日志、DApp 调用流量、账户交互行为、业务接口文档、历史审计规则和典型业务流程为输入，依次完成**控制流—状态流—价值流与运行时行为证据耦合建模**、**结构化证据约束的多智能体漏洞推演与 PoC 动态验证**、**运行时异常行为关联分析、风险评估与安全约束修复**，最终输出**漏洞证据链**、**异常行为说明**、**风险报告**、**修复建议**和**残余风险说明**，服务于蚂蚁链上资产业务中的上线前审查、高风险合约复核、运行中风险发现和漏洞整改处置。

从技术问题对应关系上看，控制流—状态流—价值流耦合建模主要解决“漏洞触发路径与资产影响路径难以统一刻画”的问题；结构化证据约束的多智能体漏洞推演主要解决“大模型推理缺少证据约束、攻击路径可执行性不足”的问题；面向链上资产操作语义的约束修复与等价性验证主要解决“补丁可能破坏业务语义、引入次生资产风险”的问题。三部分之间不是线性堆叠关系，而是形成证据传递关系：第一部分输出结构化语义图谱和候选风险路径，第二部分基于该图谱生成可执行 PoC 和漏洞证据链，第三部分再利用已验证攻击路径和业务影响路径生成修复约束并完成回归验证。

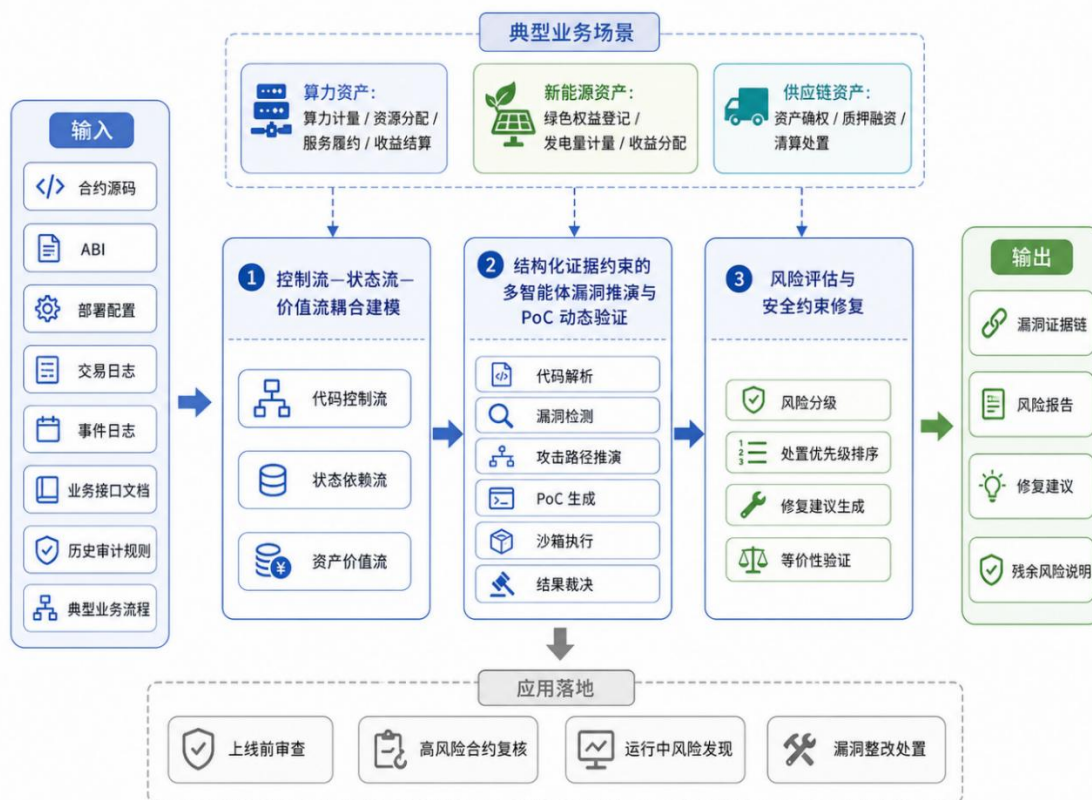


图 1 面向链上程序安全的总体技术路线

(1) 控制流—状态流—价值流耦合的链上程序语义建模方法

针对链上实体资产业务中“代码调用、状态变化、资产流转”高度耦合的问题，本项目首先构建控制流—状态流—价值流耦合的链上程序语义建模方法。如图 2 所示，该方法不是单纯抽取函数调用关系，而是将业务流程中的关键资产操作显式映射到程序图结构中，从而建立漏洞触发路径与资产影响路径之间的关联。

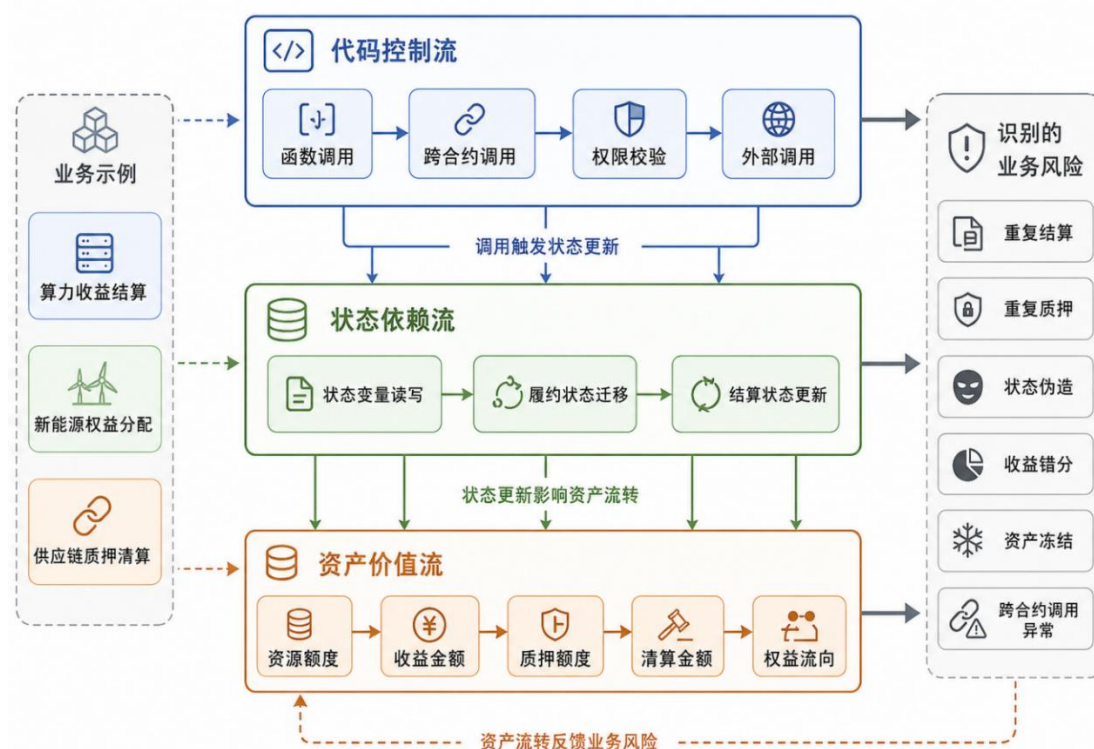


图 2 控制流—状态流—价值流耦合建模示意图

在实际业务中，系统首先对合约源码、ABI、交易日志和事件日志进行解析，抽取三类基础语义流。

第一类是**代码控制流**。系统抽取函数调用、跨合约调用、权限校验、外部调用、回调函数和异常处理逻辑。例如，在算力资源分配场景中，系统关注资源申请、资源分配、资源释放和收益结算函数之间的调用顺序；在供应链资产场景中，系统关注资产登记、仓单转让、质押、赎回和清算函数之间的调用路径。

第二类是**状态依赖流**。系统抽取状态变量读写、履约状态迁移、资产状态变更、结算状态更新和权限状态变化。例如，在算力服务履约场景中，系统重点分析“资源已分配—服务执行中—服务完成—收益可结算”等状态是否被异常跳转、重复触发或绕过；在新能源资产场景中，系统分析发电量计量、绿色权益登记、收益分配状态之间是否存在不一致。

第三类是**资产价值流**。系统抽取资产登记、资源额度、收益金额、质押额度、清算金额、

结算对象和资金/权益流向。例如，在算力收益结算场景中，系统分析算力使用量、服务履约结果和收益分配金额之间是否一致；在供应链质押融资场景中，系统分析同一资产是否可能被重复质押、异常转让或错误清算。

在上述三类语义流基础上，项目进一步构建跨层耦合关系。具体而言，系统将“**函数调用触发状态更新**”“**状态更新触发资产转移**”“**资产转移影响收益分配**”建模为跨层边，形成**控制流—状态流—价值流耦合图谱**。通过该图谱，系统能够识别以下业务相关风险：算力计量被重复提交、资源分配状态被异常覆盖、服务履约状态被伪造、收益结算被重复触发、供应链资产被重复质押、新能源收益分配路径被篡改等。

该方法的输出包括**候选漏洞位置、关键调用序列、状态依赖链、资产价值流转路径和业务影响路径**。相比传统代码扫描，该方法的核心卖点在于：它不仅判断“代码是否可疑”，还进一步判断“**该漏洞是否会影响算力计量、资源分配、服务履约、收益结算或供应链资产流转**”等具体业务环节。

（2）结构化证据约束的多智能体漏洞推演与 PoC 动态验证方法

针对大模型智能体在链上资产业务场景中容易出现推理跳跃、上下文遗漏和攻击路径不可执行的问题，本项目构建结构化证据约束的多智能体漏洞推演与 PoC 动态验证方法。该方法的关键思想是：不让大模型直接给出开放式漏洞结论，而是提出一种**证据约束多智能体漏洞推理方法**，即 **EC-MAVR(Evidence-Constrained Multi-Agent Vulnerability Reasoning)**，通过“**证据槽位—路径约束—执行反馈**”三层约束机制，将智能体推理过程限制在可验证证据、可执行交易路径和 PoC 执行结果之内。

具体而言，本项目不将多智能体作为简单的提示词编排，而是将每个候选漏洞表示为结构化六元组：

$$V = \langle F, S, A, P, T, E \rangle$$

其中，**F**表示相关函数、函数调用边和跨合约调用关系；**S**表示状态变量读写、状态更新顺序和状态迁移关系；**A**表示资产对象、金额、权益、资源额度或收益分配结果；**P**表示权限条件、余额条件、状态前置条件和业务规则约束；**T**表示可执行交易序列；**E**表示 PoC 执行日志、调用轨迹、事件输出、状态变化和资产变化等执行证据。智能体仅允许围绕上述证据槽位进行推演，不能只输出“可能存在风险”“建议检查权限”等自然语言判断。

如图 3 所示，系统设计六类角色化智能体。**代码解析 Agent** 负责从合约源码、ABI、交易日志、事件日志和业务文档中整理程序结构与业务上下文，抽取函数调用、状态变量读写、事件触发和资产字段变化等基础信息，对应六元组中的 **F, S, A**。**漏洞检测 Agent** 负责

基于漏洞规则、历史审计经验和耦合图谱发现候选风险点，并初步判断其可能违反的业务规则，对应 F, S, A, P 。**攻击路径推演 Agent** 负责在证据槽位约束下推导攻击者需要满足的调用顺序、账户角色、状态前置条件、余额条件和资产操作条件，生成候选交易序列 T 。**PoC 生成 Agent** 负责将攻击路径转化为可执行测试脚本或交易重放序列。**沙箱执行 Agent** 负责在测试链、EVM 兼容沙箱或蚂蚁链适配的受控环境中执行 PoC，并记录调用轨迹、事件输出、状态变化和资产变化。**结果裁决 Agent** 负责根据执行证据 E 判断漏洞是否真实可触发，并在 PoC 失败时对失败原因进行分类和反馈。

六类 Agent 之间传递的不是开放式对话文本，而是**统一的漏洞六元组和证据槽位**。代码解析 Agent 输出基础证据槽位，漏洞检测 Agent 补充候选风险类型和业务规则约束，攻击路径推演 Agent 将证据槽位转化为权限、状态、余额和调用顺序条件，PoC 生成 Agent 将路径条件转化为交易序列，沙箱执行 Agent 生成执行证据，结果裁决 Agent 根据执行证据更新漏洞状态。通过这种结构化状态传递机制，系统能够记录每一步推理依据，避免不同 Agent 之间只进行松散的提示词接力。



图 3 多智能体 PoC 动态验证闭环

为避免大模型自由发挥，本项目在 EC-MAVR 中引入三类核心约束。

第一类是**证据绑定约束**。每个漏洞判断必须绑定具体函数、状态变量、事件日志、资产字段和业务规则。例如，对于算力收益重复结算问题，系统必须指出涉及的结算函数、收益状态变量、收益金额字段、结算事件日志以及“同一订单或资源只能结算一次”的业务规则；对于供应链重复质押问题，系统必须指出资产确权函数、质押状态变量、资产唯一标识字段、质押事件以及“同一资产不得重复质押”的业务规则。若某一候选漏洞无法填充完整的

F, S, A, P 槽位，系统将其标记为“证据不足”，不进入 PoC 生成阶段。

第二类是**执行可达约束**。攻击路径必须能够转化为具体交易序列 T ，并满足权限、余额、资产状态、合约状态和调用顺序等前置条件。系统会检查推演路径中的调用者是否具备相应角色，账户余额或资产额度是否满足要求，目标资产是否处于可操作状态，状态变量是否满足触发条件，以及多笔交易之间的顺序是否合理。对于无法生成可执行交易序列的路径，系统将其标记为“不可达路径”，从而避免 LLM 胡编攻击步骤或生成无法执行的漏洞利用过程。

第三类是**反馈修正约束**。当 PoC 执行失败时，系统不直接丢弃候选漏洞，而是根据失败类型对 P, T, S 进行定向修正。若失败原因为权限失败，则修正账户角色或将路径标记为权限不可达；若失败原因为状态前置条件不满足，则补充状态初始化交易或调整状态迁移路径；若失败原因为余额不足，则补充资产准备步骤或修改资产条件；若失败原因为调用顺序错误，则重新排序交易序列；若失败原因为断言失败，则说明推演的资产影响不成立，系统将降低风险置信度或回退到候选风险阶段。通过这种“执行失败—失败归因—路径重写—再次验证”的闭环机制，系统能够持续减少不可执行攻击路径和模型幻觉。

从实现方式上看，项目初期采用“**结构化 Prompt Workflow + 确定性约束校验器 + 沙箱执行反馈**”的技术路线。也就是说，大模型主要负责候选漏洞解释、攻击路径推演和 PoC 草案生成，但所有关键输出都必须经过证据槽位校验、执行可达性校验和沙箱执行验证。因此，本项目中的 Agent 不是简单工具串联，而是在结构化证据约束下完成分工推理、路径生成、执行验证和反馈修正。随着项目积累更多 PoC 成功样例和失败样例，后续可进一步引入轻量级可学习策略，用于候选路径排序、PoC 失败类型分类和路径修正优先级选择，从而提升复杂漏洞验证效率。

在蚂蚁链上资产业务中，该方法可用于高风险合约复核。例如，对于上线前审查中发现的疑似收益结算风险，系统可以自动构造测试交易，验证是否存在重复结算；对于运行中发现的异常资产状态，系统可以通过交易重放验证该异常是否来自权限绕过、状态覆盖或跨合约调用异常。最终，系统输出候选漏洞六元组、结构化证据包、攻击交易序列、PoC 验证脚本、执行日志、调用轨迹、状态变化、资产变化、失败修正记录和漏洞确认结论，将“自然语言风险判断”转化为“**有证据绑定、可执行验证、可反馈修正**”的漏洞证据链，降低误报率，提高安全复核效率。

同时，本项目严格限定 PoC 生成与验证的安全边界。所有 PoC 生成、交易重放和攻击路径验证均在受控沙箱、测试链或脱敏业务样例中完成，仅用于漏洞确认、误报过滤和修复验证，不面向真实链上环境执行攻击，也不输出可直接用于真实攻击的利用脚本。

(3) 面向链上资产操作语义的约束修复与等价性验证方法

针对链上程序修复容易阻断局部漏洞却破坏业务逻辑的问题，本项目研究面向链上资产操作语义的约束修复与等价性验证方法。该方法不追求完全自动化上线补丁，而是面向安全团队和研发团队提供经过验证的修复建议、补丁候选和残余风险说明。

在修复建议生成阶段，系统首先**根据已验证攻击路径和业务影响路径确定修复目标**。例如，对于算力收益重复结算问题，修复目标可能是补充结算状态锁、限制重复调用、调整状态更新顺序；对于供应链资产重复质押问题，修复目标可能是增加资产唯一性校验、限制资产状态迁移路径、补充清算前置条件；对于新能源收益分配异常问题，修复目标可能是修正计量状态与收益分配状态之间的绑定关系。

在修复约束建模阶段，系统引入三类约束。第一类是**安全约束**，要求补丁必须阻断已通过 PoC 验证的攻击路径；第二类是**状态等价约束**，要求补丁不能破坏正常业务流程中的状态迁移，例如不能使“服务履约完成”无法进入“收益结算”状态；第三类是**资产语义等价约束**，要求补丁不能改变正常资产登记、资源分配、收益结算、质押清算和权益分配逻辑。例如，补丁不能导致合法收益无法结算、合法资产无法转让、合法质押无法赎回，也不能改变正常业务下的收益分配对象和分配比例。

在补丁验证阶段，系统基于历史正常交易、业务规则样例和测试链构造回归测试集，对补丁前后的行为进行对比。验证内容包括：**已确认攻击路径是否被阻断；正常业务交易是否仍能执行；状态迁移是否保持一致；资产流转和收益分配结果是否保持一致；是否引入资产冻结、重复结算、权限异常或收益错分等次生风险**。只有同时满足安全约束、状态等价约束和资产语义等价约束的修复建议，才会作为推荐方案输出。

最终，系统输出修复建议、修复依据、补丁验证结果、受影响业务路径和残余风险说明，支撑安全团队、研发团队和业务团队协同完成漏洞整改。该方法的核心创新在于**把链上程序修复从“漏洞模式级补丁生成”提升为“资产操作语义约束下的修复与等价性验证”**，更适合算力、新能源、供应链等实体资产上链场景。

创新性与可落地性

本项目的创新性主要体现在以下三个方面。第一，提出**控制流—状态流—价值流耦合的链上程序语义建模方法**。该方法突破传统智能合约安全分析主要关注函数调用、局部代码模式和状态变量读写关系的局限，将链上程序中的代码执行逻辑、业务状态迁移和资产价值流转统一纳入分析框架，刻画“函数调用如何触发状态变化、状态变化如何影响资产流转、资

产流转异常如何形成业务风险”的传导链路，从而建立漏洞触发路径与资产影响路径之间的映射关系。第二，**提出结构化证据约束下的多智能体漏洞推演机制**。该机制不依赖大模型直接给出开放式风险判断，而是将智能体推理过程约束在合约调用证据、状态依赖证据、资产流转证据和业务规则证据之内，并结合 PoC 执行、交易重放和沙箱反馈对推理结果进行校正，使漏洞判断从自然语言解释进一步转化为可执行、可复核的证据链。第三，**提出面向链上资产操作语义的安全约束修复与等价性验证方法**。该方法在生成修复建议时同时考虑安全约束、状态等价约束和资产语义等价约束，避免补丁虽然阻断局部漏洞，却破坏正常业务流程中的状态转移、资产登记、收益结算、质押清算和权益分配逻辑，从而提升链上程序修复结果的业务一致性和工程可用性。

本团队不是传统智能合约审计团队，而是**以智能安全、鲁棒推理、流量行为分析、区块链应用监管和安全评测为基础**，面向蚂蚁链上实体资产业务构建智能体化安全验证方法。团队成员在多智能体协同推理、鲁棒优化、可信推断、流量行为分析、区块链应用监管和安全评测方面具有长期研究积累，可支撑项目中的结构化证据约束推理、PoC 执行反馈修正、运行时行为分析和业务语义一致性验证等关键任务。同时，项目将通过引入公开漏洞基准、开源审计工具、蚂蚁测试环境和学生驻场实习，补齐智能合约安全工程适配能力。项目前期已围绕智能合约漏洞检测工具、DeFi 安全分析、LLM 合约审计和智能合约修复方法完成文献调研与技术路线梳理，并已初步设计基于 Slither、Foundry 和 Hardhat 的漏洞验证实验基座。

本项目具备较好的数据基础和实验验证条件。项目前期可依托公开智能合约漏洞数据集、开源合约、公开审计报告和公开 PoC 样例开展基础验证，形成可复现的实验基准。具体而言，可选取 **SmartBugs Curated**、**SolidiFI-benchmark**、**SWC Registry**、**Etherscan/Sourcify** 公开合约、公开审计报告以及 **DeFiHackLabs** 等攻击复现样例作为初始数据来源。其中，**SmartBugs Curated** 可用于重入、整数溢出、时间戳依赖、访问控制缺陷等典型漏洞的检测基准验证；**SolidiFI-benchmark** 可用于注入型缺陷合约的识别、定位和误报分析；**SWC Registry** 可作为漏洞类型归类、规则模板设计和风险描述标准化的参考依据；**Etherscan/Sourcify** 公开合约可用于验证方法在真实合约结构、复杂继承关系和跨合约调用场景下的适用性；**DeFiHackLabs** 等公开攻击复现样例可用于 PoC 生成、交易重放和执行反馈机制的验证。在公开数据验证基础上，项目将进一步构造面向算力计量、资源分配、服务履约、收益结算、供应链质押清算、新能源权益登记与收益分配等场景的高保真业务样例，用于评估方法在链上实体资产业务中的有效性和可迁移性。

在工具链与实验环境方面，项目将采用“**静态分析工具、动态验证工具、图谱建模工具、智能体编排框架和沙箱执行环境**”相结合的技术路线。静态分析层面，拟使用 solc、Slither、Surya 等工具解析 Solidity 合约源码、ABI、函数调用关系、继承关系、权限检查逻辑和状态变量读写关系，为控制流和状态流建模提供基础数据。动态验证层面，拟使用 Foundry、Hardhat、Anvil/Ganache、Echidna、Mythril 或 Manticore 等工具支撑单元测试、模糊测试、符号执行、交易重放和 PoC 执行验证。图谱建模层面，拟使用 NetworkX、Neo4j 或轻量级图数据库构建控制流—状态流—价值流耦合图谱，实现漏洞路径、状态依赖路径和资产影响路径的统一表达。智能体实现层面，拟基于 LangChain、AutoGen、CrewAI 或自研轻量级 Agent 编排框架，构建代码解析 Agent、漏洞检测 Agent、攻击路径推演 Agent、PoC 生成 Agent、沙箱执行 Agent 和结果裁决 Agent 的协同机制。环境封装层面，拟使用 Docker、测试链节点、EVM 兼容沙箱和蚂蚁链适配 SDK 构建可复现实验环境，保证漏洞验证过程具备可追踪性、可复核性和可迁移性。

面向蚂蚁链上资产业务场景，本项目可优先服务于**算力资产上链、新能源资产上链和供应链资产上链等典型业务中的安全治理需求**。在算力资产上链或算力 RWA 场景中，系统可用于分析算力资源登记、算力计量、资源分配、服务履约和收益结算等流程中是否存在重复计量、重复结算、履约状态伪造、资源状态覆盖、收益分配异常等风险。在新能源资产上链场景中，系统可用于分析发电量计量、绿色权益登记、收益分配、价格更新和多方结算等逻辑中是否存在计量状态与结算状态不一致、权益重复登记、收益错配、价格更新异常或权限绕过等风险。在供应链资产上链场景中，系统可用于分析资产确权、仓单流转、应收账款登记、质押融资、赎回和清算处置等流程中是否存在重复质押、异常转让、清算条件绕过、资产冻结、权限异常或跨合约状态不一致等风险。上述能力可嵌入链上资产业务的上线前安全审查、高风险合约复核、运行中异常状态排查和漏洞整改处置流程，为业务研发、安全评审和风险治理提供闭环支撑。

在产学协同与业务适配阶段，项目将在公开数据和高保真样例验证的基础上，进一步结合蚂蚁链上资产业务的脱敏样例、测试环境和安全治理规范开展适配验证。为支持模型构建、漏洞推演、动态验证和修复评估，项目可依托以下几类脱敏数据与环境条件。第一，链上程序数据，包括典型业务合约源码或字节码、ABI、部署参数、合约间调用关系、权限配置、角色配置和升级代理配置等，用于**构建控制流、调用关系和权限约束模型**。第二，链上运行数据，包括测试链或脱敏环境中的交易日志、事件日志、调用 trace、状态变更记录、失败交易样例和异常交易样例等，用于**支持交易重放、状态依赖分析和资产价值流追踪**。第三，

业务语义数据，包括算力资产、新能源资产、供应链资产等场景中的业务流程说明、状态机定义、字段字典、资产登记规则、收益分配规则、质押清算规则、异常处置规则和上线审查规范等，**用于建立资产操作语义约束**。第四，安全治理数据，包括历史审计报告、已确认漏洞样例、误报样例、修复前后合约样例、测试用例和安全评审规则等，用于优化漏洞推演模板、风险分级规则和修复验证策略。第五，实验环境支持，包括蚂蚁链测试环境、沙箱节点、RPC/SDK 接口、脱敏账户、测试资产、事件订阅接口和必要的链上数据导出能力等，用于验证 PoC 动态执行、交易重放和补丁再验证模块。上述数据与环境条件并不要求一次性提供完整生产链路，可按照“**公开样例—脱敏样例—测试环境联调**”的方式分阶段接入，优先满足最小验证场景所需的合约、日志、规则和沙箱执行条件。项目实施过程中将采用最小必要字段和脱敏化处理方式，仅保留漏洞证据绑定、交易重放、状态验证和修复回归所需信息，降低业务数据接入成本和合规风险。

项目实施过程中将严格遵循最小必要、脱敏使用和受控验证原则。项目不依赖真实用户身份数据、真实私钥、生产环境资产控制权限或线上攻击入口；所有 PoC 生成、交易重放和漏洞验证均限定在测试链、沙箱环境或脱敏业务样例中完成。对于业务合约、日志和规则数据，项目将优先采用脱敏化、样例化和最小字段化处理，仅保留漏洞验证、状态建模和业务语义约束分析所必需的信息。最终交付成果不输出可直接作用于生产环境的攻击脚本，而是形成漏洞证据链、风险等级、影响路径、修复建议、补丁验证结果和残余风险说明，服务于安全团队、研发团队和业务团队的协同复核与整改。

总体而言，本项目具备清晰的落地实施路径，可按照“**公开数据集基础验证—高保真业务样例验证—蚂蚁链测试环境适配—业务流程嵌入试点**”的路线逐步推进。第一阶段，基于公开漏洞数据集、开源合约和公开 PoC 样例验证基础漏洞检测、智能体推演和动态执行能力；第二阶段，围绕算力、新能源、供应链等链上实体资产场景构造高保真业务样例，验证控制流—状态流—价值流耦合建模和资产语义约束修复能力；第三阶段，结合蚂蚁提供的测试链、脱敏合约和业务规则完成工具链适配与接口联调；第四阶段，将原型能力嵌入上线前安全审查、高风险合约复核、运行中风险发现和漏洞整改处置流程，形成可演示、可评测、可扩展的链上程序安全分析原型系统。该落地路径既能够保证项目研究工作的科学性和可验证性，也能够支撑后续在蚂蚁链上资产业务安全治理中的持续应用和能力扩展。

2. 研究计划

2.1. 项目期限：以实际合同签字生效日期为准，合同期建议1年。

2.2. 项目计划：

阶段	研究内容	时间	提交结果
1	业务场景调研与实验基座构建。 围绕蚂蚁链上实体资产业务，梳理算力计量、资源分配、服务履约、收益结算、新能源权益登记、供应链确权、质押清算等典型流程；整理公开智能合约漏洞数据集、审计报告、PoC 样例和基线工具；构建算力收益结算、供应链质押清算、新能源收益分配等高保真业务样例；确定系统架构、评价指标和实验环境。	T ~ T+2 个月	开题报告 ；业务场景调研报告；典型链上资产业务流程与风险清单；公开数据集与基线工具说明；高保真业务样例设计文档； 系统总体架构设计文档 。
2	控制流—状态流—价值流耦合建模。 面向算力收益结算、供应链质押清算、新能源权益分配等场景，解析合约源码、ABI、交易日志和业务规则，抽取代码控制流、状态依赖流和资产价值流，构建耦合图谱，识别状态更新异常、重复结算、重复质押、跨合约调用异常等候选风险路径。	T+3 ~ T+5 个月	控制流—状态流—价值流 耦合建模模块 ；链上程序耦合图谱构建算法说明；典型业务样例上的漏洞路径识别实验报告； 阶段性算法原型 ；论文和专利创新点初稿。
3	多智能体漏洞推演与 PoC 动态验证。 基于耦合图谱，构建代码解析、漏洞检测、攻击路径推演、PoC 生成、沙箱执行和结果裁决等角色化 Agent；在测试链、EVM 兼容沙箱或蚂蚁链适配环境中，对候选风险进行 PoC 生成、交易重放和执行反馈验证，过滤误报并形成漏洞证据链。	T+6 ~ T+8 个月	多智能体漏洞推演原型； PoC 动态验证模块 ；交易重放与沙箱验证脚本；典型场景 漏洞证据链报告 ；中期报告；论文初稿；专利技术交底书初稿。
4	风险评估、安全约束修复与系统集成。 对已验证漏洞进行风险分级和处置优先级排序；生成安全约束修复建议，并通过回归测试、交易重放和沙箱再验证，确认补丁阻断攻击路径且不破坏资源分配、服务履约、收益结算、资产确权和清算处置等业务逻辑；完成系统集成和结题验证。	T+9 ~ T+12 个月	完整智能体驱动型链上程序安全分析原型系统；风险评估与优先级排序模块；安全约束修复建议与等价性验证模块；源代码、部署文档、接口说明和系统演示材料；技术指标评测报告； 结题报告 ； 论文投稿稿件 ； 专利申请材料 。

3. 预期成果

本项目围绕“链上程序漏洞检测、PoC 动态验证、风险评估与安全约束修复”这一主线，预期形成一套**面向链上程序安全审查的智能体驱动型原型系统**，具体预期成果如下。

3.1 算法原型与系统交付

本项目预期交付一套面向链上程序安全审查的智能体驱动型漏洞验证与安全修复原型系统。系统面向算力计量、资源分配、服务履约、收益结算、新能源权益登记、供应链确权、

质押融资与清算处置等链上资产业务场景，围绕“建模—推演—验证—评估—修复—再验证”流程，形成以下核心模块：

模块一：控制流—状态流—价值流耦合建模模块

该模块解析合约源码、ABI、交易日志、事件日志、业务接口文档和历史审计规则，抽取代码控制流、状态依赖流和资产价值流，构建链上程序耦合图谱。模块重点刻画函数调用如何触发状态变化、状态变化如何影响资产流转、资产流转异常如何形成业务风险。输出候选漏洞位置、关键调用序列、状态依赖链、资产价值流转路径和业务影响路径。

模块二：结构化证据约束的多智能体漏洞推演模块

该模块构建代码解析 Agent、漏洞检测 Agent、攻击路径推演 Agent、PoC 生成 Agent、沙箱执行 Agent 和结果裁决 Agent。各智能体基于控制流、状态流和价值流证据进行分工推演，输出漏洞类型、触发条件、关键调用序列、状态变化链、资产影响路径和 PoC 验证方式。该模块主要用于识别算力收益重复结算、供应链重复质押、新能源收益分配异常等高风险业务场景中的候选漏洞。

模块三：PoC 动态验证与漏洞证据链生成模块

该模块在测试链、EVM 兼容沙箱或蚂蚁链适配的受控环境中执行 PoC、交易重放和攻击路径验证，并根据执行日志、调用轨迹、状态变化和资产变化判断漏洞是否真实可利用。系统仅在受控环境和脱敏样例中进行验证，不面向真实链上环境执行攻击。模块输出可复核漏洞证据链、误报过滤结果和漏洞确认结论。

模块四：风险评估与处置优先级排序模块

该模块结合 PoC 验证结果、资产价值流、合约状态、账户权限、攻击成本和业务关键路径，对已确认漏洞进行风险分级和处置优先级排序。模块面向算力收益结算、供应链质押清算、新能源权益分配等场景，输出风险等级、影响范围、触发条件、潜在经济影响和处置建议。

模块五：安全约束修复建议与等价性验证模块

该模块基于已验证攻击路径和业务影响路径生成修复建议，并引入安全约束、状态等价

约束和资产语义等价约束，验证补丁是否阻断攻击路径，同时不破坏权限控制、状态转移、资源分配、资产结算和收益分配逻辑。模块输出修复建议、修复依据、补丁验证结果和残余风险说明。

3.2. 论文与专利成果

围绕项目中的核心创新点，计划投稿 CCF-A 类或蚂蚁认可的网络安全、软件工程、区块链安全相关会议/期刊论文 1-2 篇。论文选题重点包括：

1. 控制流—状态流—价值流耦合的链上程序语义建模方法，研究漏洞触发路径与资产影响路径之间的映射关系；
2. 结构化证据约束下的多智能体漏洞推演与 PoC 动态验证方法，研究如何通过执行反馈校正智能体推理偏差；
3. 面向链上资产操作语义的约束修复与等价性验证方法，研究补丁在阻断攻击路径的同时如何保持业务语义一致性。

项目计划协助蚂蚁和/或其关联公司申请国内或国际发明专利 1 项，拟定专利方向为：一种面向链上资产操作语义的多智能体漏洞验证与安全约束修复方法。

专利交付材料包括技术交底书、创新点说明、流程图、实施例和实验支撑材料。

3.3. 技术指标与评测结果

项目拟在公开智能合约漏洞数据集、公开审计报告、开源合约、公开 PoC 样例以及高保真模拟链上资产业务样例上开展验证，并与传统静态分析工具、模糊测试工具和大模型直接审计方法进行对比。预期达到以下指标：

1. **业务场景覆盖**：构建不少于 3 类高保真链上资产业务样例，覆盖算力计量/收益结算、供应链确权/质押清算、新能源权益登记/收益分配等场景。
2. **漏洞类型覆盖**：支持重入、权限控制缺陷、未检查外部调用、跨合约状态异常、价格/预言机操纵、重复结算、重复质押等不少于 5 类典型链上风险分析。
3. **耦合建模能力**：能够从合约源码、ABI、交易日志、事件日志和业务规则中抽取控制流、状态流和价值流，并建立漏洞触发路径与资产影响路径之间的映射。
4. **漏洞识别效果**：相比传统静态分析基线，复杂漏洞路径识别覆盖率提升 15% 以上。

- 5.误报过滤效果：**通过 PoC 动态验证和执行反馈，相比单一静态检测或 LLM 直接判断方法，疑似漏洞误报率降低 **30%** 以上。
- 6.证据链输出能力：**对已验证漏洞输出可执行验证脚本、执行日志、调用轨迹、状态变化、资产影响说明和漏洞确认结论。
- 7.修复验证能力：**对典型漏洞生成安全约束修复建议，并通过回归测试、交易重放或沙箱再验证，确认补丁能够阻断已验证攻击路径，且不破坏状态迁移、资产结算和收益分配等核心业务逻辑。

4.人力、设备等投入及项目预算

4.1. 人力投入（包括全部参与项目的人员）

人员姓名	所属机构与职务	人员服务费 (元/月)	参与项目时间 (折合全时人月数)	人员服务费总 计 (元)	承担职责	来蚂蚁实习 时间（学 生）
曹阳	东南大学 副研究员	3125	6	18750	PI	
王良民	东南大学 教授	3125	6	18750	项目主要成员	
桂杰	东南大学 教授	3125	6	18750	项目主要成员	
张静	东南大学 教授	3125	6	18750	项目主要成员	
袁亚丽	东南大学 副教授	3125	6	18750	项目主要成员	
吴钊涛	东南大学 硕士	3125	6	18750	项目主要成员	T+3 至 T+9 月
庞久宇	东南大学 硕士	3125	6	18750	项目主要成员	T+5 至 T+11 月
涂宁慧	东南大学 硕士	3125	6	18750	项目主要成员	T+6至 T+12 月

上述人员为乙方为本项目配备的项目组成员，乙方应保证项目组成员为本项目投入充足的研究时间，以确保在符合有关工作时间的法规要求下按时保质地完成研发项目。如若需要对上述人员进行调整，双方应根据项目进度充分协商后共同邮件确认调整人员名单。本项目需要乙方项目负责人至蚂蚁和/或其关联公司现场开展项目交流至少【5】次，且需要项目组成员入职蚂蚁和/或其关联公司实习，实习生人数不低于【3】人，每位实习生实习时间不低于【6】个月，实习具体的时间可参考上表（以上人员的服务费用、差旅费用等均包含在本合同研究

费用内；入职蚂蚁和/或其关联公司的实习生费用不额外支付，实习费（如差旅、住宿、餐费等费用）均包含在本合同研究费用内）。

4.2. 设备投入

设备名称	数量	价格（元）	总计（元）	备注
高性能 GPU 计算加速卡	2	30000	60000	用于本地部署代码大模型、合约语义嵌入模型、多智能体推理缓存和批量评测，避免敏感合约样例和脱敏日志频繁上传第三方云端环境
大容量固态硬盘与存储阵列	4	5000	20000	用于存储合约源码、交易日志、事件日志、PoC 执行日志、模型检查点和实验数据

4.3 项目预算

类别	总计（元）	备注
① 人员支出	150000	与4.1对应
② 研发支出	140000	
出差/会议费用	30000	高校来往蚂蚁现场交流费用 10,000 元；国内项目交流/会议费用 10,000 元；项目实习生差旅、住宿、餐补、保险等费用 10,000 元
设备费	80000	与4.2对应
其它费用	30000	测试链、沙箱、交易重放环境与基线工具评测 20,000 元；云算力/API 调用/模型推理服务 10,000 元；
③ 直接费用	290000	①+②
④ 间接费用	10000	学校学院管理费
总计	300000	③+④

5. 学者个人简历

曹阳（项目负责人 PI）

现任东南大学网络空间安全学院智能安全系副研究员、博士生导师。博士毕业于香港大学 (HKU) 控制工程专业，师从 Prof. James Lam（欧洲科学院院士，IEEE Fellow）及 Dr. Michael Z. Q. Chen（青千）。目前担任区块链应用与监管教育部工程研究中心委员、江

苏省应用数学科学研究中心课题共同负责人，入选科技部和江苏省专家库。

【与本项目的关联及贡献】

多智能体协同推理与漏洞推演（支撑研究目标二）：曹阳近年来围绕网络空间安全中的智能决策、风险识别和动态防御问题开展研究，形成了复杂网络建模、多智能体协同推理、鲁棒优化与安全控制等方面的理论基础。该经验可支撑本项目中代码解析 Agent、漏洞检测 Agent、攻击路径推演 Agent、PoC 生成 Agent、沙箱执行 Agent 和结果裁决 Agent 的协同机制设计，提升链上程序漏洞推演与执行反馈校正能力。

鲁棒优化与风险评估排序（支撑研究目标二、三）：针对链上程序漏洞确认后仍需开展风险分级、处置优先级排序和残余风险说明的问题，他在鲁棒优化、安全控制和多目标决策方面的积累，可支撑项目将 PoC 验证结果、资产价值流、账户权限、攻击成本和业务关键路径纳入统一评估框架，形成面向算力、新能源、供应链等链上资产业务的风险排序方法。

区块链应用监管与链上安全治理（支撑研究目标一、三）：作为区块链应用与监管教育部工程研究中心委员，曹阳老师参与区块链应用监管、链上风险识别和智能合约安全治理相关研究工作。该背景可支撑项目构建控制流—状态流—价值流耦合图谱，并在安全约束修复阶段验证补丁不破坏资产登记、资源分配、服务履约、收益结算和清算处置等链上资产操作语义。

【代表性成果】

[1] Y. Cao, S. Dharani, M. Sivakumar, A. Cader, R. Nowicki, “Mittag-Leffler synchronization of generalized fractional-order reaction-diffusion networks via impulsive control,” Journal of Artificial Intelligence and Soft Computing Research, vol. 15, no.1, pp. 25-36, 2025.

[2] Y. Cao, A. Chandrasekar, T. Radhika, and V. Vijayakumar, “Input-to-state stability of stochastic Markovian jump genetic regulatory networks,” Math. Comput. Simul., vol. 222, pp. 174-187, 2024.

[3] Y. Cao, P. Guo and L. Guerrini, “Hopf bifurcation of the ring unidirectionally coupled Toda oscillators with distributed delay,” Int. J. Bifurcation Chaos, vol. 34, no. 12, Art. no. 2450148, 2024.

[4] Y. Cao, K. Udhayakumar, K. P. Veerakumari, and R. Rakkiyappan, “Memory sampled data control for switched-type neural networks and its application in image secure communications,” Math. Comput. Simul., vol. 201, pp. 564-587, 2022.

[5] Y. Cao, S. Ramajayam, R. Sriraman, and R. Samidurai, “Leakage delay on stabilization of finite-time complex-valued BAM neural network: Decomposition approach,” Neurocomputing, vol. 463, pp. 505-513, 2022.

[6] Y. Cao, “Bifurcations in an Internet congestion control system with distributed delay,” Appl. Math. Comput., vol. 347, pp. 54-63, 2019.

[7] Y. Cao, R. Samidurai, and R. Sriraman, “Robust passivity analysis for uncertain neural networks with leakage delay and additive time-varying delays by using general activation function,” Math. Comput. Simul., vol. 155, pp. 57-77, 2019.

[8] Y. Cao, L. Zhang, C. Li, and M. Z. Q. Chen, “Observer-based consensus tracking of nonlinear agents in hybrid varying directed topology,” IEEE Trans. Cybern., vol. 47, no. 8, pp. 2212-2222, 2017.

王良民（项目主要成员）

现任东南大学网络空间安全学院教授、博士生导师。博士毕业于西安电子科技大学密

码学专业，曾分别师从顾冠群教授（院士）、Alex Kot 教授（IEEE Fellow）、李飞飞教授（IEEE Fellow/ACM Fellow）开展博士后与访问学者研究，长期从事计算机网络、信息处理、数据库安全、区块链应用、物联网/车联网安全、匿名网络及设备监管、数据安全与网络交易管理等交叉领域研究。

【与本项目的关联及贡献】

区块链安全架构与应用监管（支撑研究目标一）：王良民长期开展架构驱动的安全计算技术研究，应用领域覆盖区块链应用架构、DApp 加密流量识别和网络交易监管。该经验可支撑本项目面向链上实体资产业务梳理算力计量、资源分配、服务履约、收益结算、供应链确权、质押清算等典型流程，并构建控制流—状态流—价值流耦合建模框架。

可信支撑与安全计算（支撑研究目标三）：他主持或参与互不信任环境下基于区块链的网构软件可信支撑平台、工业网络安全可信管理平台等研究任务，在安全计算、可信支撑、隐私保护协议和可验证存储方面具有系统积累。该背景可支撑项目设计安全约束、状态等价约束和资产语义等价约束，验证修复建议不会破坏正常资产登记、收益分配、质押赎回和清算处置逻辑。

工程化验证与基线评测（支撑研究目标二、三）：王良民在网络安全真实场景识别、DApp 监管和智能交易管理方面具有丰富项目经验，可支撑项目搭建公开数据验证、高保真业务样例验证、测试链与沙箱验证相结合的评测流程。其经验有助于开展基线工具对比、交易重放、PoC 动态验证和系统集成评估，提升原型系统面向蚂蚁链上资产业务的落地可用性。

【代表性成果】

[1] Haiqin Wu, Boris Dudder, Liangmin Wang, Zhenfu Cao, Jun Zhou, Xia Feng: Survey on Secure Keyword Search over Outsourced Data: From Cloud to Blockchain-assisted Architecture. ACM Comput. Surv., 56(3): 63:1-63:40, 2024.

[2] Yu'e Jiang, Liangmin Wang, Hsiao-Hwa Chen, Xuemin Shen: Physical Layer Covert Communication in B5G Wireless Networks - its Research, Applications, and Challenges. Proc. IEEE, 112(1): 47-82, 2024.

[3] Yiliang Liu, Hsiao-Hwa Chen, Liangmin Wang: Physical Layer Security for Next Generation Wireless Networks: Theories, Technologies, and Challenges. IEEE Commun. Surv. Tutorials, 19(1): 347-376, 2017.

[4] Qiang Zhou, Liangmin Wang, Huijuan Zhu, Tong Lu, Victor S. Sheng: WF-Transformer: Learning Temporal Features for Accurate Anonymous Traffic Identification by Using Transformer Networks. IEEE Trans. Inf. Forensics Secur., 19: 30-43, 2024.

[5] Tao Jiang, Xu Yuan, Qiong Cheng, Yulong Shen, Liangmin Wang, Jianfeng Ma: FairECom: Towards Proof of E-Commerce Fairness Against Price Discrimination. IEEE Trans. Dependable Secur. Comput., 21(4): 3528-3544, 2024.

[6] Yu'e Jiang, Liangmin Wang, Hsiao-Hwa Chen: Covert Communications With Randomly Distributed Adversaries in Wireless Energy Harvesting Enabled D2D Underlaying Cellular Networks. IEEE Trans. Inf. Forensics Secur., 18: 5401-5415, 2023.

[7] Xia Feng, Qichen Shi, Qingqing Xie, Liangmin Wang: P2BA: A Privacy-Preserving Protocol With Batch Authentication Against Semi-Trusted RSUs in Vehicular Ad Hoc Networks. IEEE Trans. Inf. Forensics Secur., 16: 3888-3899, 2021.

[8] Tao Jiang, Wenjuan Meng, Xu Yuan, Liangmin Wang, Jianhua Ge, Jianfeng Ma: ReliableBox: Secure and Verifiable Cloud Storage With Location-Aware Backup. IEEE Trans. Parallel Distrib. Syst., 32(12): 2996-3010, 2021.

[9] Ke Cheng, Liangmin Wang, Yulong Shen, Yangyang Liu, Yongzhi Wang, Lele Zheng: A Lightweight Auction Framework for Spectrum Allocation with Strong Security Guarantees. INFOCOM 2020: 1708-1717.

桂杰（项目主要成员）

现任东南大学青年首席教授，2024 至 2025, 2020 至 2022 全球前 2% 顶尖科学家榜单(the World's Top 2% of Scientists by Stanford University, USA)，ACM 高级会员 (ACM Senior Member)，IEEE 高级会员 (IEEE Senior Member)，国家青年高层次人才（国家级四青人才）。

【与本项目的关联及贡献】

对抗样例生成与漏洞验证（支撑研究目标二）：桂杰长期致力于对抗样本自动化生成与鲁棒性评测，对抗构造、语义变异和对抗性测试有系统积累。该经验可支撑本项目中攻击路径推演 Agent 与 PoC 生成 Agent 的设计，围绕链上程序的跨合约调用、状态更新异常、重复结算、重复质押等风险构造高质量测试样例，并在受控沙箱或测试链环境中验证候选漏洞是否真实可触发。

鲁棒学习与误报过滤（支撑研究目标二）：针对智能体安全分析中可能出现的推理偏差、误报和不可执行攻击路径，他在对抗训练与鲁棒优化方面的研究可用于提升漏洞检测 Agent、结果裁决 Agent 的稳定性。其经验有助于设计执行反馈驱动的误报过滤机制，使系统在 PoC 执行、交易重放和沙箱验证后形成可复核的漏洞证据链。

泛化能力与评测体系（支撑研究目标二、三）：链上程序漏洞形态会随业务流程、合约组合和资产操作方式变化而持续演化。他在分布外泛化与安全评测体系方面的积累，可支撑项目构建覆盖算力、新能源、供应链等链上资产业务的阶梯式评测方案，验证智能体推演与约束修复方法在未知漏洞路径和复杂业务样例中的泛化能力。

【代表性成果】

- [1] Y. Zhang, J. Gui*, M. Dong, X. Cong, Y. Cao, X. Gong, Y. Tang, J. Kwok, "Divide and Conquer: Frequency-Aware Contrastive Adversarial Training for Robust Point Cloud Classification," IEEE Transactions on Information Forensics and Security, vol. 20, pp. 7709-7723, 2025.
- [2] C. Jiang, J. Wang, M. Dong, J. Gui*, X. Shi, Y. Cao, Y. Tang, J. Kwok, "Improving Fast Adversarial Training via Self-Knowledge Guidance," IEEE Transactions on Information Forensics and Security, vol. 20, pp. 3772-3787, 2025.
- [3] S. Zhai, Z. He, X. Cong, J. Hou, J. Gui*, J. You, X. Gong, J. Kwok, Y. Tang, "Unrevealed Threats: A Comprehensive Study of the Adversarial Robustness of Underwater Image Enhancement Models," IEEE Transactions on Multimedia, vol. 27, pp. 9532-9541, 2025.
- [4] J. Gui, X. Cong, C. Peng, Y. Tang, J. Kwok, "Fooling the Image Dehazing Models by First Order Gradient," IEEE Transactions on Circuits and Systems for Video Technology, vol. 34, no. 7, pp. 6265-6278, 2024.
- [5] B. Cao, J. Cao*, L. Hua, X. Guan, B. Liu, C. He, J. Gui*, J. Kwok, "No Place to Hide: Dual Deep Interaction Channel Network for Fake News Detection With Data Augmentation" IEEE Transactions on Computational Social Systems, vol. 12, no. 6, pp. 4013-4024, 2025.

张静（项目主要成员）

现任东南大学网络空间安全学院智能安全系教授，IEEE 高级会员 (Senior Member, Since 2019)，常年担任 AAAI、IJCAI、KDD、ICML、NeurIPS、ICLR、ICDM、WSDM、SDM、

CIKM、ECAI 等人工智能相关领域顶级和权威国际会议程序委员会成员(PC/SPC Member)，ACM 会员、CCF 协同计算专委会执行委员。

【与本项目的关联及贡献】

大模型幻觉消除与可信推断（支撑研究目标二、三）：本项目的多智能体漏洞推演需要在合约调用证据、状态变化证据、资产流转证据和业务规则证据约束下完成。张静在大模型安全与可信推断方向的积累，可指导代码解析 Agent、漏洞检测 Agent 和结果裁决 Agent 的结构化输出设计，降低上下文遗漏、事实幻觉和不可复核结论风险，提升漏洞证据链与修复依据的可信度。

黑盒攻击与智能体对抗推演（支撑研究目标二）：针对链上程序中跨合约调用异常、权限绕过、状态覆盖和重复结算等隐蔽风险，他在黑盒攻击和强化学习驱动攻击方向的研究可支撑攻击路径推演 Agent 与 PoC 生成 Agent 的策略设计。其经验有助于构建高质量红队测试环境，在受控沙箱、测试链和脱敏样例中持续探测并校正智能体的决策边界。

投毒鲁棒性与安全约束（支撑研究目标三）：链上程序修复不能只阻断局部攻击，还必须保持资产登记、资源分配、服务履约、收益结算和清算处置等业务语义一致。他在噪声与投毒鲁棒学习、安全约束建模方面的成果，可支撑补丁候选的回归测试、交易重放和沙箱再验证，降低修复建议破坏业务逻辑或引入次生风险的可能性。

【代表性成果】

- [1] Maochang Zhao & Jing Zhang*. Highly imperceptible black-box graph injection attacks with reinforcement learning. In the 39th AAAI Conference on Artificial Intelligence (AAAI-2025), Philadelphia, Pennsylvania, USA.
- [2] Xiaoqian Jiang & Jing Zhang*. FedClean: A general robust label noise correction for federated learning. In the 42nd International Conference on Machine Learning (ICML-2025), Vancouver, Canada.
- [3] Xiaoqian Jiang, Jing Zhang*, Ming Wu, & Cangqi Zhou. TiFedCrowd: Federated crowdsourcing with time-controlled incentive. IEEE Transactions on Emerging Topics in Computational Intelligence, 9(2): 1514–1526.
- [4] Cangqi Zhou, Jinling Shang, Jing Zhang*, Qianmu Li, & Dianming Hu. Topic-attentive encoder-decoder with pre-trained language model for keyphrase generation. In the 21st International Conference on Data Mining (ICDM-2021), Auckland, New Zealand.
- [5] Zijian Ying, Jing Zhang*, Qianmu Li, Ming Wu, & Victor S. Sheng. A little truth injection but a big reward: Label aggregation with graph neural networks. IEEE Transactions on Pattern Analysis and Machine Intelligence, 46(5): 3169–3182.

袁亚丽（项目主要成员）

现任东南大学网络空间安全学院副教授、硕士/博士生导师、国家重点研发计划青年项目首席科学家，江苏省网络空间安全能力研究与发展专委会副主任，东南大学 OpenHarmony 技术俱乐部主任。在 TDSC、TIFS、TON、INFOCOM 等国际期刊和会议上发表论文 40 余篇。主持重点研发青年科学家项目、国家自然科学基金、江苏省自然科学基金等，参与国防重点科研项目。被邀请作为 TPC 和 SPC 参与多个计算机网络国际会议。获得江苏省网络空间安全学会青年科技奖、江苏省双创博士、南方电网科学研究院有限责任公司科技进步奖二等奖等。受邀首届 CCF 中国网络大会演讲嘉宾。

【与本项目的关联及贡献】

细粒度链上行为特征挖掘（支撑研究目标一）：袁亚丽长期聚焦细粒度流量特征挖掘与异常检测，相关经验可迁移到链上程序的交易日志、事件日志、ABI 调用和业务规则解

析中。她可支撑项目从合约源码、链上交易和业务接口文档中抽取函数调用、权限检查、状态变量读写、资产登记、资源分配、收益结算等关键语义，为控制流—状态流—价值流耦合建模提供高质量输入。

多视角特征融合与耦合图谱构建（支撑研究目标一）：链上实体资产业务同时包含代码控制流、状态依赖流和资产价值流，具有明显的异构性与时序性。她在多视角特征融合方面的研究可支撑项目融合合约调用、状态迁移、事件日志、资产流向和业务规则，构建面向算力收益结算、供应链质押清算、新能源权益分配等场景的链上程序耦合图谱。

真实场景识别与工程评测（支撑研究目标一、二）：本项目需要在公开数据集、高保真业务样例、测试链和蚂蚁链适配环境中逐步验证效果。她在加密与匿名通信分析中的真实场景高精度识别和工程化评测经验，可支撑项目建立可复用的数据处理、基线对比和指标评测流程，帮助降低复杂漏洞识别中的误报并提升系统落地可用性。

【代表性成果】

- [1] H. Mei, G. Cheng and Y. Yuan, "High Precision and Efficient Anonymous Traffic Classification in the Real-World," in IEEE Transactions on Networking, vol. 33, no. 3, pp. 966-981, June 2025.
- [2] Y. Xu, X. Fang, Z. Xu, K. Song, Y. Yuan and G. Cheng, "M-ETC: Improving Multi-Task Encrypted Traffic Classification by Reducing Inter-Task Interference," 2024 IEEE 23rd International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom), Sanya, China, 2024, pp. 271-278.
- [3] Y. Xu, J. Li, Y. Hou, X. Huang, Y. Yuan and G. Cheng, "TriViewNet: Achieve Accurate Tor Hidden Service Classification by Multi-View Feature Extraction and Fusion," 2024 IEEE 23rd International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom), Sanya, China, 2024, pp. 559-566.
- [4] Y. Li et al., "CoDA: Cross-Domain Few-Shot Website Fingerprinting via Contrastive Prototype Alignment," 2025 IEEE 24th International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom), Guiyang, China, 2025, pp. 1752-1758.